Reporte

Equipo 16	
Nombre: Lesly Adamaris Cotlame Nieto Christopher Bethancourt Contreras Francisco Mora Ruiz	**Matrícula**: 2226958 2226948 2226912
Nombre del curso: Componentes de lógica de negocios.	**Nombre del profesor**: Miguel Ángel Gómez Marroquín
Módulo Netacad: PIA, apartado 3: Implementación	**Actividad**: Documentación de seguridad, roles y permisos de Eventos Nova.
Fecha: 05/11/2026 (revisión documental) · Entrega oficial del PIA: 06/11/2026	

Bibliografía (Formato APA)

- Biryukov, A., Dinu, D., Khovratovich, D., & Josefsson, S. (2021). Argon2 memory-hard function for password hashing and proof-of-work applications (RFC 9106). RFC Editor. https://www.rfc-editor.org/rfc/rfc9106
- OWASP Foundation. (s. f.). Cross-site request forgery prevention cheat sheet. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
- OWASP Foundation. (s. f.). Session management cheat sheet. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- Ramírez, S. (s. f.). FastAPI [Documentación oficial]. https://fastapi.tiangolo.com/

Objetivo:

Describir los controles de seguridad implementados en Eventos Nova (autenticación, sesiones, autorización por rol, protección CSRF y configuración por entorno), su verificación y las limitaciones pendientes antes de un despliegue público.

Procedimiento:

Documentación de seguridad - Eventos Nova

Fuente: docs/SEGURIDAD_Y_PERMISOS.md, docs/SEGURIDAD_MATRIZ_PERMISOS.md y src/application/seguridad.py del commit e3c98d9 (el commit 9c72bc7, publicado después, solo añade una regla de .gitattributes). Estado: implementado y probado en el entorno local; no es una declaración de que el sistema esté listo para Internet.

1. Roles

Rol	Permisos	Operaciones (sin / con las 3 de sesión)	Resumen
Administrador	12	32 / 35	Pagos y verificación, devoluciones, cobranza, autorizaciones, importe adicional de sustitución, revisión administrativa, catálogo (registrar, editar, activar) y cuentas
Coordinador	13	50 / 53	Eventos, propuestas, contratos, ciclo del evento, solicitudes, registrar y asignar proveedores, anotar la respuesta del proveedor; no registra pagos ni administra cuentas
Proveedor	2	4 / 7	Solo lo propio: mis asignaciones, su ficha, su vista del evento y su respuesta

El Cliente no tiene cuenta. Matriz deny-by-default: 73 operaciones protegidas más 4 públicas (GET /, GET /health, GET /ready, POST /auth/inicio-sesion); una ruta ausente de la matriz se rechaza con 403. Decisiones S-1 a S-9 aprobadas el 01/11/2026 (ADR-011).

2. Autenticación y sesiones

Control	Implementación
Contraseñas	Argon2id (argon2-cffi); mínimo 12 caracteres; no igual al correo o nombre
Sesión	Token opaco de 256 bits; en la base solo su SHA-256 (tabla sesion)
Cookie	eventosnova_sesion: HttpOnly, SameSite=Strict; Secure con HTTPS (obligatoria en producción)
Caducidad	30 minutos de inactividad y 8 horas absolutas; cierre, baja y cambio de contraseña invalidan sesiones
CSRF y Origin	Cabecera X-CSRF-Token en toda escritura y comprobación del encabezado Origin
Intentos	5 fallos por correo e IP (25 por IP) bloquean 15 minutos (HTTP 429); persistido en intento_acceso

Control	Implementación
Cabeceras	CSP estricta en /app/, X-Frame-Options DENY, nosniff, Referrer-Policy, HSTS en producción
Límite de cuerpo	256 KiB (HTTP 413)
Primer administrador	scripts/crear_administrador.py; sin credenciales predeterminadas

3. Configuración por entorno

Variable	Local	Producción
EVENTOSNOVA_ENTORNO	local	produccion
EVENTOSNOVA_ AUTENTICACION	activa (puede desactivarse solo en local)	no se puede desactivar
EVENTOSNOVA_COOKIE_ SEGURA	0	1 obligatorio
/docs, /redoc, /openapi.json	visibles	ocultos salvo EVENTOSNOVA_DOCS=1
FORWARDED_ALLOW_IPS	—	* en render.yaml (confianza en el proxy TLS)

4. Privacidad de la información comercial (Bloque A)

COR-05 (commit e2697a6): las vistas del proveedor dejaron de devolver el texto condiciones del contrato del Cliente, que puede incluir importes. Solo devuelven servicioContratadoId, servicio, estado y respuesta. Se verificó con test_h01_h02_proveedores, una comprobación de claves exactas en test_seguridad y el recorrido en Chrome (un proveedor alterno ve el evento; el original ya no; el cruce entre proveedores y las rutas privilegiadas responden 403).

COR-03 (commits 69816ed y 97ea865): solo una cuenta con rol Proveedor queda vinculada a un proveedor; el frontend oculta el campo y el backend normaliza. Coincide con el CHECK ck_usuario_proveedor_solo_si_rol_proveedor (migración 0006). COR-12 añadió mostrar/ocultar contraseña sin cambiar la política.

5. Verificación

N.º	Verificación
1	tests/test_seguridad.py en memoria y PostgreSQL: 401 sin sesión en todas las rutas protegidas, matriz completa por rol, CSRF, Origin, cookies, bloqueo, caducidad y aislamiento del proveedor.

N.º	Verificación
2	Una prueba comprueba que cada ruta de la API está en la matriz y viceversa.
3	Navegador: probar_seguridad_navegador.mjs y el recorrido del Bloque A (30/30, tres repeticiones).

6. Pendiente antes de un despliegue público

N.º	Pendiente
1	HTTPS real: lo aportará la plataforma; no se ha probado (Render no desplegado).
2	Limitación por IP detrás de proxy: requiere confiar en X-Forwarded-For de la plataforma.
3	Sin recuperación de contraseña por correo, MFA ni bitácora de auditoría persistente.
4	Gestión de secretos y respaldos cifrados de la base en la plataforma.
5	Revisión de seguridad independiente y limitación general de peticiones.